



# Foo Inc. Security Program Plan

By Edwin Deras Jr and Marwin Deras



In collaboration with  
**Eagle Eye Security**

## Table of Contents

|                                                                                                                                                    |           |
|----------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Security Plan .....</b>                                                                                                                         | <b>3</b>  |
| <b>Strategic Objectives .....</b>                                                                                                                  | <b>4</b>  |
| <b>Security Program Development .....</b>                                                                                                          | <b>4</b>  |
| <b>Objective 1 .....</b>                                                                                                                           | <b>4</b>  |
| Risk Management Policies and Processes .....                                                                                                       | 4         |
| <b>Objective 2 .....</b>                                                                                                                           | <b>5</b>  |
| Update cybersecurity practices based on risk assessment.....                                                                                       | 5         |
| <b>Objective 3 .....</b>                                                                                                                           | <b>5</b>  |
| Adopt an organization-wide approach to managing cybersecurity risk .....                                                                           | 5         |
| <b>Objective 4 .....</b>                                                                                                                           | <b>6</b>  |
| Consistently monitor cybersecurity risks of organizational assets.....                                                                             | 6         |
| <b>Objective 5 .....</b>                                                                                                                           | <b>6</b>  |
| Implement policies to monitor and mitigate supply chain risks associated with<br>products and services provided and used by the organization. .... | 6         |
| <b>Quarterly Objective KPI's .....</b>                                                                                                             | <b>7</b>  |
| <b>Security Program Management .....</b>                                                                                                           | <b>8</b>  |
| <b>Security Program Assessment.....</b>                                                                                                            | <b>9</b>  |
| <b>Report: .....</b>                                                                                                                               | <b>14</b> |
| Security Program Development .....                                                                                                                 | 14        |
| <b>Security Program Management:.....</b>                                                                                                           | <b>15</b> |
| <b>Gantt Chart .....</b>                                                                                                                           | <b>16</b> |
| <b>Resource Assessment: .....</b>                                                                                                                  | <b>16</b> |
| <b>Security Program Assessment .....</b>                                                                                                           | <b>17</b> |
| <b>Expected End-of-Year State: .....</b>                                                                                                           | <b>19</b> |
| <b>Gap Analysis .....</b>                                                                                                                          | <b>19</b> |
| <b>Conclusion: .....</b>                                                                                                                           | <b>20</b> |

# Security Program Plan

## Foo Inc.

May 5, 2025

### Security Plan

#### Company Background:

**Foo, Inc.** is a business in the video game industry. The business currently employs 40 employees and is known for many successful video games. The video game company is responsible for notable franchises such as Grand Theft Robbery Series, Fortnite 2, and Star Wares. These games have both online and multiplayer elements to them. The company also distributed these games on multiple platforms like app stores, consoles, or PC gaming.

This risk assessment looks at how **Foo Inc.** uses resources available to put effective security controls in place. These controls are designed to identify and address **vulnerabilities**, with the broader goal of **protecting company assets** and ensuring the overall **integrity** and **reliability** of programs.

The current evaluation is a Tier 1 risk assessment, which will be followed by Tier 2 and Tier 3 assessments to ensure a thorough analysis of all possible threats and vulnerabilities. This assessment identifies known risks and weaknesses linked to incomplete or insufficient application of the NIST SP 800-30 framework, selected for this business type. Once the risk assessment analysis is finalized, this report will be updated to reflect the latest findings, including any vulnerabilities or observations noted by the independent assessment team Eagle Eye. The data gathered during this process may inform us of better strategic decision-making for this organization.

## Strategic Objectives

|             |                                                                                                                                            |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| Objective 1 | Formalize risk management policies and processes.                                                                                          |
| Objective 2 | Update cybersecurity practices based on risk assessment.                                                                                   |
| Objective 3 | Adopt an organization-wide approach to managing cybersecurity risk.                                                                        |
| Objective 4 | Consistently monitor cybersecurity risks of organizational assets                                                                          |
| Objective 5 | Implement policies to monitor and mitigate supply chain risks associated with products and services provided and used by the organization. |

## Security Program Development

### Objective 1

#### Risk Management Policies and Processes

Formalizing cyber risk management policies means creating a clear and structured approach to how to deal with cybersecurity risks. Building a system helps individuals in an organization understand their role in keeping data systems safe. The framework used includes clear guidelines for identifying, mitigating, and monitoring risks, along with defining roles, response procedures, and regular updates.

The policies with the most importance are:

1. Access Control and Authentication
2. Network Security and Monitoring
3. Incident Response and Availability

| Initiatives                                          | Duration         | Staff Member                      |
|------------------------------------------------------|------------------|-----------------------------------|
| Assign cybersecurity roles and responsibilities      | <b>2 hours</b>   | C-Suite                           |
| Conduct Tier 2 and Tier 3 risk assessment            | <b>100 hours</b> | Security Assessment Team          |
| Document observed cyber risks                        | <b>5 hours</b>   | Designated to John                |
| Map preliminary security strategies                  | <b>20 hours</b>  | Designated to Ashley              |
| Define key policy areas based on assessment findings | <b>1 hour</b>    | C-Suite & Eagle Eye Security Team |

## Objective 2

### Update cybersecurity practices based on risk assessment

Following a thorough review of company risk assessment, the team found multiple areas of weakness. Therefore, the company will focus on the elements of **access control and authentication, network security and monitoring, and incident response and availability**. The following initiatives are used to strengthen weaknesses in the company, ensuring that these weaknesses are addressed and updated.

| Initiatives                           | Duration      |
|---------------------------------------|---------------|
| Update identity verification systems  | 3 days        |
| Modernize perimeter defenses          | 2 weeks       |
| Develop incident response protocols   | 24 hours      |
| Assess security program effectiveness | 1 day 4 hours |
| Conduct breach simulations            | 16 hours      |

## Objective 3

### Adopt an organization-wide approach to managing cybersecurity risk

| Initiatives                                                  | Duration |
|--------------------------------------------------------------|----------|
| Assigning executive cybersecurity roles                      | 6 hours  |
| Conduct role assignment to define security responsibilities  | 12 hours |
| Host a security awareness seminar                            | 1 day    |
| Host executive strategy meeting for cyber risk ownership     | 5 hours  |
| Approve and document privilege access across all departments | 2 days   |

## Objective 4

Consistently monitor cybersecurity risks of organizational assets

| Initiatives                                                                  | Duration |
|------------------------------------------------------------------------------|----------|
| Eagle Eye installation will monitor regular IP addresses and server activity | 2 hours  |
| Set up automatic alerting system for unauthorized accessing                  | 5 hours  |
| Hire employees for network security and firewall updates                     | 3 weeks  |
| Access and authentication training for employees                             | 1 day    |
| Establish a secure communication channel for reporting cyber risks           | 1 day    |

## Objective 5

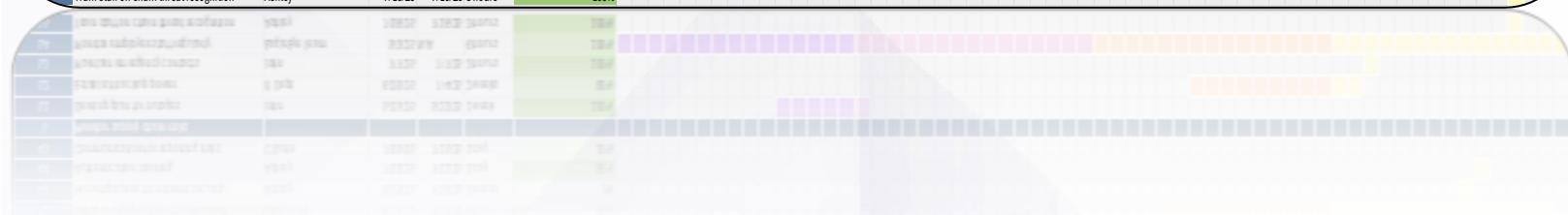
Implement policies to monitor and mitigate supply chain risks associated with products and services provided and used by the organization.

| Initiatives                                            | Duration |
|--------------------------------------------------------|----------|
| Develop contingency plans for critical systems outages | 1 week   |
| Establish backup power and network redundancy          | 2 weeks  |
| Maintain emergency vendor contacts for rapid response  | 3 hours  |
| Monitor third-party service reliability                | 6 hours  |
| Train staff on supply chain threat recognition         | 3 hours  |

## Quarterly Objective KPI's

| Overall Status      | On track                                                           | Issues                                                                    | At Risk                                                                              | Issues                                                                             | On Track                                                                                                                                                    |
|---------------------|--------------------------------------------------------------------|---------------------------------------------------------------------------|--------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Objectives</b>   | (Objective 1)<br>Formalize risk management policies and processes. | (Objective 2)<br>Update cybersecurity practices based on risk assessment. | (Objective 3)<br>Adopt an organization-wide approach to managing cybersecurity risk. | (Objective 4)<br>Consistently monitor cybersecurity risks of organizational assets | (Objective 5)<br>Implement policies to monitor and mitigate supply chain risks associated with products and services provided and used by the organization. |
| <b>Initiative 1</b> | Assign cybersecurity roles and responsibilities                    | Update identity verification systems                                      | Assigning executive cybersecurity roles                                              | Eagle Eye installation will monitor regular IP addresses and server activity       | Develop contingency plans for critical systems outages                                                                                                      |
| <b>Status</b>       | Roles Assigned +100%                                               | MFA deployed +15%                                                         | Exec Roles drafted +10%                                                              | -40%<br>Eagle Eye delayed                                                          | Cloud backups live +100% completed                                                                                                                          |
| <b>Initiative 2</b> | Conduct Tier 2 and Tier 3 risk assessment                          | Modernize perimeter defenses                                              | Conduct role assignment to define security responsibilities                          | Set up automatic alerting system for unauthorized accessing                        | Establish backup power and network redundancy                                                                                                               |
| <b>Status</b>       | Tier 3 Assessment done +80% completed                              | Ongoing issues -10%                                                       | Training Pending 0%                                                                  | Alert System Bugs -20%                                                             | Generators installed +80%                                                                                                                                   |
| <b>Initiative 3</b> | Document observed cyber risks                                      | Develop incident response protocols                                       | Host a security awareness seminar                                                    | Hire employees for network security and firewall updates                           | Maintain emergency vendor contacts for rapid response                                                                                                       |
| <b>Status</b>       | Risks documented +90% completed                                    | Assessment -70%                                                           | +10%<br>Seminar Postponed                                                            | Employee Training -5%                                                              | Vendor list updated +100%                                                                                                                                   |
| <b>Initiative 4</b> | Map preliminary security strategies                                | Assess security program effectiveness                                     | Host executive strategy meeting for cyber risk ownership                             | Access and authentication training for employees                                   | Monitor third-party service reliability                                                                                                                     |
| <b>Status</b>       | Areas need mapping +70%                                            | Assessment ongoing +20%                                                   | -5%<br>Meeting Postponed                                                             | Auth training in progress +60%                                                     | Services established +90%                                                                                                                                   |
| <b>Initiative 5</b> | Define key policy areas based on assessment findings               | Conduct breach simulations                                                | Approve and document privilege access across all departments                         | Establish a secure communication channel for reporting cyber risks                 | Train staff on supply chain threat recognition                                                                                                              |
| <b>Status</b>       | Policy areas defined +80%                                          | Simulations not started 0%                                                | Needed communication across departments -10%                                         | +10% needed communication                                                          | +100% completed                                                                                                                                             |

(To see the Gantt chart in full detail, a separate attachment will be provided)





## Security Program Assessment

| Function | Category                              | Initiatives                                          |
|----------|---------------------------------------|------------------------------------------------------|
| Identity | Identify Assets                       | Eagle Eye will monitor IP activity                   |
|          | Identify Business Environment         | Develop contingency plan for critical system outages |
|          | Identify Governance Policies          | Assign roles and responsibilities                    |
|          |                                       | Define policy areas based on assessment policies     |
|          | Identifying Risk Assessment           | Conduct Tier 2 and Tier 3 risk assessments           |
|          |                                       | Document observed risks                              |
|          | Identify Risk Management              | Map preliminary security strategies                  |
|          |                                       | Update identity verification systems                 |
|          |                                       | Modernize preliminary defense                        |
|          | Identify Supply Chain Risk Management | Monitor third party service reliability              |
|          |                                       | Train staff on chain threat recognition              |

Current State at end-of-year

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Target State

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Progress is showing, but governance is still weak. While policies exist, they don't fully adhere to the governance set by certain laws and regulations. The company also risks prioritizing releasing assets over security practices. Supply chains are also acknowledged but not fully endorsed because of budget cuts. To hit tier 3, formalize ownership roles and leadership.

| Function | Category                                        | Initiatives                                                                             |
|----------|-------------------------------------------------|-----------------------------------------------------------------------------------------|
| Protect  | Identify Management and Access Control          | Update identity verification systems                                                    |
|          |                                                 | Approve and document privilege access                                                   |
|          | Awareness and Training                          | Host a security awareness seminar                                                       |
|          |                                                 | Access and Authentication training for employees                                        |
|          | Data Security Protection                        | Establish a secure connection channel for reporting risks                               |
|          | Information Protection Processes and Procedures | Maintain emergency vendor contacts for rapid response                                   |
|          | Protecting Resources Through Maintenance        | Maintain emergency vendor contacts for rapid response                                   |
|          |                                                 | Establish backup power and network redundancy                                           |
|          | Managing Protective Technology                  | Modernize parameter defense                                                             |
|          |                                                 | Modernize parameter defense<br>Hire employees for network security and firewall updates |

Current State at end-of-year

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Target State

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

For protect functions, foundations exist, but some gaps remain. Therefore, the current state at the end-of-year is tier 2. Phishing attacks are still successfully high, and patching is slow. To achieve tier 3, mandate training and tie security upgrades to release cycles. Identity is therefore a priority for improvement.

| Function | Category                        | Initiatives                                              |
|----------|---------------------------------|----------------------------------------------------------|
| Detect   | Anomalies and Event Detection   | Set up automatic alerting system for unauthorized access |
|          | Security Continuous Monitoring  | Eagle Eye will monitor IP activity                       |
|          | Maintaining Detection Processes | Conduct breach simulations                               |

Current State at end-of-year

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Target State

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Strong monitoring. Response is slower than expected, tools detect anomalies and events, but team members don't react to alerts during crunch hours. Employee monitoring is sound. To hit tier 4, integrate alerts into regular workflow and additional training.

| Function | Category              | Initiatives                                                     |
|----------|-----------------------|-----------------------------------------------------------------|
| Respond  | Response Planning     | Develop incident response protocols                             |
|          | Communications        | Establish a secure connection channel for reporting cyber risks |
|          | Analysis              | Access security program effectiveness                           |
|          | Mitigation Activities | Modernize perimeter defense                                     |
|          | Improvements          | Conduct breach simulations                                      |

Current State at end-of-year

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Target State

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Current plans are strong. Communication avenues can be expanded with external training and additional communication channels. To hit tier 3, run quarterly breach simulations with leadership.

| Function | Category                             | Initiatives                                           |
|----------|--------------------------------------|-------------------------------------------------------|
| Recover  | Recovery Planning Process            | Develop contingency plans for critical system outages |
|          |                                      | Establish backup power and network redundancy         |
|          | Improvements                         | Assess security program effectiveness                 |
|          | Internal and External Communications | Maintain emergency vendor contacts for rapid response |

Current State at end-of-year

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Target State

|   |   |   |   |
|---|---|---|---|
| 1 | 2 | 3 | 4 |
|---|---|---|---|

Incredibly weak infrastructures. While backups exist, they are inconsistent, and recovery times have not been tested. To hit tier 3, prioritize recovery drills and exercise for critical systems.

### Improvements

The security program assessment lays out the fundamental challenges that Foo Inc. face with security implementation. Eagle Eye maintains the notion that recovery NIST CSF function is within the agenda of most importance. In the scenario in which an attack is conducted, the current state of Foo Inc. faces hardships in recovering company assets and function. Eagle Eye recommends implementing mandatory drills for recovery practice, targeting critical systems and infrastructures. Annual reports should be conducted by Eagle Eye to review the security implementation and test the core NIST CSF functions for improvement. If these improvements are not made, additional mentorship and planning will be conducted by the Eagle Eye team.

# Report:

## Security Program Development

The previous pages, pages 4-7, are used to develop a security program based on the specific needs of the company. This plan includes estimates of person-hours and group-hours required to complete each task. Each person and group are identified using key performance indicators (KPIs) that will be used to measure the success of each objective. This will ensure the security, stability, and overall performance of the organization. Below are the five new objectives:

1. Formalize risk management policies and processes.
2. Update cybersecurity practices based on risk assessment.
3. Adopt an organization-wide approach to managing cybersecurity risk.
4. Consistently monitor cybersecurity risks of organizational assets
5. Implement policies to monitor and mitigate supply chain risks associated with products and services provided and used by the organization.

### Key Performance Indicators

1. The objective 1 is the successful implementation of risk management policies and processes
2. The objective 2 is the successful implementation of cybersecurity practices based on risk assessment. This addresses all known vulnerabilities.
3. The objective 3 is the successful adoption of organization-wide implemented monitoring of risks.
4. The objective 4 is the consistent monitoring of known cybersecurity risks and protection of organization assets and products.
5. The objective 5 is the consistent monitoring and mitigation of supply chain risks used by the organization, such as reviewing suppliers and vendors.

## Security Program Management:

The Security Program Management section introduces a one-year management plan for implementation in the cybersecurity program. The initial security team consists of four designated staff members to take on the tasks of different assigned tasks.

Participation and involvement in tasks are calculated based on the expectation that each full-time staff member contributes a minimum of 40 hours per week. These calculations consider only weekdays (Monday through Friday), excluding weekends to ensure accurate person-hour tracking for work-related activities. This approach maintains consistency in measuring productivity and resource allocation across the team.

| Objective | Task                                     | Person-Hours Required | Staff Assigned                                        |
|-----------|------------------------------------------|-----------------------|-------------------------------------------------------|
| 1         | Formalize risk policies and procedures   | 128 hours             | Staff 1<br>Staff 2<br>Upper management,               |
| 2         | Update security practices                | 140 hours             | Its department<br>Eagle Eye<br>Staff 3                |
| 3         | Organizational approach to managing risk | 95 hours              | C-Suite<br>Leadership<br>Staff 1                      |
| 4         | Monitoring risks of assets               | 443 hours             | Eagle Eye Leadership<br>Staff 1<br>Staff 4<br>C-Suite |
| 5         | Monitor supply chain risks               | 132 hours             | Staff 1<br>Staff 2<br>IT Department<br>Eagle Eye      |

## Gantt Chart

The Gantt Chart on page 8 shows the expected time frame for tasks. The Gantt chart is a resource for time management planning and progress tracking.

### Milestones

The following can be used to track key performance indicator performance:

| Milestone | Progress                                                  |
|-----------|-----------------------------------------------------------|
| 1         | Completion of risk management policies                    |
| 2         | Completion of risk assessment and cybersecurity practices |
| 3         | Completion of organizational-wide cyber security plans    |
| 4         | Implementation of cybersecurity monitoring system         |
| 5         | Completion of supply chain risk management                |

## Resource Assessment:

Based on this current management plan, the security team has adequate resources to fulfill program objectives at this stage. However, as the implementations advance, increased demand might necessarily need additional staff members. A staffing reassessment is recommended after three to six months to evaluate potential needs.

This one-year management plan details task assignments, staff member allocation, future projected progress, and key milestones for each necessary objective. To ensure a continuous alignment with goals, the plan will undergo necessary reviews and changes as needed.



## Security Program Assessment

The Eagle Eye team performed a security program assessment in accordance with the NIST CSF Functions. The categories consist of identify, protect, detect, respond, and recover. These functions are rated on a tiered system, between tier 1 and 5. Tier 1 is the lowest score, and Tier 5 is the highest score. Also, a gap analysis is conducted between the end-of-year score and the target goals.

### *Identify:*

| Objective                             | Task     | NIST CSF Function            |
|---------------------------------------|----------|------------------------------|
| Identify Assets                       | Identify | Asset Management             |
| Identify Business Environment         |          | Business Environment         |
| Identifying Risk Assessment           |          | Risk Assessment              |
| Identify Risk Management              |          | Risk Management Strategy     |
| Identify Supply Chain Risk Management |          | Supply Chain Risk Management |

### *Protect:*

| Objective                                       | Task    | NIST CSF Function              |
|-------------------------------------------------|---------|--------------------------------|
| Identify Management and Access Control          | Protect | Access Control                 |
| Awareness and Training                          |         | Awareness and Training         |
| Data Security Protection                        |         | Data Security                  |
| Information Protection Processes and Procedures |         | Information Protection Process |
| Protecting Resources Through Maintenance        |         | Maintenance                    |
| Managing Protective Technology                  |         | Protective Technology          |

*Detect:*

| Objective                       | Task   | NIST CSF Function     |
|---------------------------------|--------|-----------------------|
| Anomalies and Event Detection   | Detect | Anomalies and Events  |
| Security Continuous Monitoring  |        | Continuous Monitoring |
| Maintaining Detection Processes |        | Detection Processes   |

*Respond:*

| Objective             | Task    | NIST CSF Function |
|-----------------------|---------|-------------------|
| Response Planning     | Respond | Response Planning |
| Communications        |         | Communications    |
| Analysis              |         | Analysis          |
| Mitigation Activities |         | Mitigation        |
| Improvements          |         | Improvements      |

*Recover:*

| Objective                            | Task    | NIST CSF Function |
|--------------------------------------|---------|-------------------|
| Recovery Planning Process            | Recover | Recovery Planning |
| Improvements                         |         | Improvements      |
| Internal and External Communications |         | Communications    |

## Expected End-of-Year State:

Based on the security program assessment conducted by the Eagle Eye team, the following function tiers are expected at the end of the year:

**Identify:** Tier 3

**Protect:** Tier 3

**Detect:** Tier 4

**Respond:** Tier 3

**Recover:** Tier 3

## Gap Analysis

There are currently large gaps in multiple categories between the NIST CSF Functions' end-of-year performance and expected performance. Notably, there is a 1 tier difference in identify, protect, detect, and respond categories. There is a 2-tier difference in the recovery function. To meet the end-of-year criteria, the following objectives are suggested:

**Objective 1:** Develop strong leadership roles for supply chain management and responsibilities.

**Objective 2:** Initiate employee training against phishing attacks and conduct mandatory exercises for practice.

**Objective 3:** Integrate alerts for occurring and conduct practice for responding to alerts, testing for time and effectiveness.

**Objective 4:** Expand communication efforts for effective communication when attacks occur.

**Objective 5:** Develop a recovery process and plan for when an attack occurs. Exercise plan of action on a regular basis, regulating how the recovery process is conducted.

## Conclusion:

This report outlines a 1-year management plan to guide **Foo Inc's** organization implementation, which aligns strategic objectives with realistically measurable tasks, measurable KPI's, and NIST CSF functions. Each objective's activities are mapped to the NIST CSF framework (Identify, Protect, Detect, Respond, and Recover), ensuring compliance with industry standards.

By executing this plan, the organization will systematically close security issues, enhance operational status, and reinforce leadership and teamwork in cybersecurity practices.

To maintain a steady infrastructure, the plan incorporates periodic reviews, scheduled between 3 to 12 months, to assess progress against KPIs and adapt to evolving threats or regulatory changes.